

Name: A. PURUSOTHAMAN
Reg no: 192421405
Subject: Ethical Hacking
Sub. code: ITA 1407
Date: 30/01/2026
Faculty: Dr. M.S. Ganarajan.

Questions:

You discover a critical zero-day vulnerability in widely-used medical device software during an authorized test. The vendor is unresponsive for 80 days despite multiple attempts to contact them. Using a responsible disclosure framework, explain your next steps and justify the timeline.

Introduction:

When a critical zero-day vulnerability is discovered in widely used medical device software during an authorized security test, the researcher has the ethical and professional responsibility to protect patients while ensuring the vendor has a fair opportunity to solve the issue. A coordinated Vulnerability disclosure (CVD) framework provides a structured approach that balances public safety, vendor cooperation and transparency.

Step 1: Verify and document that vulnerability

The first step is to confirm that the vulnerability is genuine, reproducible, and accurately documented. This includes recording the affected software versions, technical details, severity, potential impact on patients, and any available evidence. Proof of concept testing should remain confidential and should not be released publicly. Well prepared documentation enables the vendor to understand and address the issues more efficiently.

Step 2: Notify a coordinating Authority.

Since the vulnerability affects medical devices, I would report it to an appropriate coordinating organization such as CERT/CC or the relevant national cybersecurity authority. If applicable, I would also inform the appropriate medical device regulator (such as U.S Food Administration). The final message would state that, unless a response is received within 7-14 days, the issue will be escalated through coordinated disclosure.

Step 3: Notify a coordinating authority

Since the vulnerability affects medical devices, I would report it to an appropriate coordination organization such as CERT/CC or the relevant national cybersecurity authority. If applicable, I would also inform the appropriate medical device regulator the equivalent authority in the affected country. These organizations can help coordinate communication with the vendor, assess the patient safety risks, and encourage timely remediation.

Step 4: Prepare a public security advisory.

If the vendor remains unresponsive after the additional coordination period, I would publish a responsible security of the vulnerability, the potential impact, and any temporary mitigation measures that users can implement. However, I would avoid releasing exploit code or unnecessary technical skills that could enable attackers to exploit the vulnerability before a patch becomes available.

Conclusion:-

Following a coordinated vulnerability disclosure framework ensures that patient safety remains the highest priority while maintaining ethical standards. By documenting the vulnerability, attempting multiple forms of communication, involving trusted coordination authorities, and disclosing the issue responsibly only after reasonable efforts have failed, researchers can protect the public without unnecessarily increasing the risk of exploitation.

— / — — — × — — — × — — — .